
Authentication & Authorization



Mengamankan RESTful API

- Ada kalanya kita butuh mengamankan RESTful API yang kita buat
- Atau ingin membatasi pihak yang boleh mengakses RESTful API yang kita buat
- Salah satunya adalah dengan menggunakan Authentication dan Authorization



Authentication dan Authorization

Authentication :

- Memvalidasi kredensial untuk memverifikasi pemilik identitas
- Contoh proses Authentication adalah proses login menggunakan username dan password, dan banyak yang lainnya.

Authorization :

- Authorization adalah proses yang dilakukan setelah proses Authentication
- Memvalidasi apakah pemilik identitas memiliki hak akses untuk mengakses resource yang diminta
- Contoh proses Authorization adalah Access-Control List, dan banyak yang lainnya.



Contoh Authentication & Authorization

- Basic Auth
- API-Key
- OAuth 2
- dan lain-lain



Basic Auth

- Authentication sederhana menggunakan username dan password
- Cukup menggunakan header Authorization
- <https://tools.ietf.org/html/rfc7617>

Contoh :

- Authorization : Basic base64(username:password)



API-Key

- Authentication sederhana menggunakan API-Key atau Secret Key
- Cukup menggunakan header sesuai dengan yang diinginkan dan value berisi API-Key atau secret key

Contoh :

- API-Key : random-api-key-urnod2i3unr8qy78n8nrf83ufior2u3fior



OAuth 2

- Mekanisme Authentication dan Authorization yang saat ini sangat populer
- Banyak digunakan untuk integrasi antara aplikasi Mobile dan Server
- <https://tools.ietf.org/html/rfc6749>
- <https://tools.ietf.org/html/rfc6750>

OAuth 2

